

Incident Response Playbook: Phishing and Credential Compromise

This playbook defines the standard operating procedure for a Security Operations Center (SOC) responding to suspected phishing attacks and credential compromise incidents. It is intended for Tier 1 and Tier 2 analysts and covers detection, triage, containment, eradication, recovery, and post-incident review.

1. Detection

Phishing incidents are typically detected through one of three channels: automated email security gateway alerts flagging suspicious attachments or links, user-reported suspicious emails submitted via the report-phishing button, or anomalous authentication alerts from the SIEM indicating a login from an unusual location or device shortly after a suspicious email was delivered to that user.

2. Triage

Upon receiving an alert, the Tier 1 analyst confirms whether the email is malicious by checking sender domain reputation, inspecting embedded URLs in a sandboxed environment, and reviewing email headers for spoofing indicators such as SPF, DKIM, and DMARC failures. If credential submission is suspected, the analyst immediately checks authentication logs for the targeted user for any successful logins following the phishing email delivery time.

3. Containment

If credential compromise is confirmed or highly suspected, containment actions must be taken within 15 minutes: disable the affected user account, force a password reset, revoke all active session tokens, and enable mandatory multi-factor re-enrollment. If the phishing email was sent to multiple recipients, the malicious sender domain and URLs should be blocked at the email gateway and web proxy simultaneously.

4. Eradication

Eradication involves removing the malicious email from all mailboxes organization-wide using the email security platform's search-and-purge capability, and scanning the affected endpoint for any dropped malware using EDR tools, since some phishing campaigns deliver a credential harvesting page as well as a secondary malware payload.

5. Recovery

Once the account is secured and any malware removed, the user's access is restored with a new, unique password and re-enrolled MFA. The analyst should also review what other systems the compromised account had access to and check for signs of lateral movement or data access during the compromise window.

6. Post-Incident Review

Every confirmed phishing incident is logged with a severity rating and reviewed in the weekly SOC retrospective. Common findings feed back into detection rule tuning -- for example, if a phishing campaign bypassed the email gateway, the retrospective should identify why and propose a new detection rule. Metrics tracked include time to detect, time to contain, and number of users who clicked the malicious link versus number who reported it.

Severity Classification Guide

Low: Phishing email detected and blocked before any user interaction. Medium: User clicked a link but did not submit credentials, or opened an attachment that did not execute. High: Credentials were submitted to a phishing page but no evidence of account misuse yet. Critical: Confirmed unauthorized access using compromised credentials, or malware execution confirmed on an endpoint.